

Security+ 4.6 · Access Controls

Mestre CyberSec — PDF baseado na aula do Professor Messer · 4.6 — Access Controls (7:49) · [vídeo original ↗](#) · [YouTube ↗](#)

Modelos: ACL (por recurso, lista); MAC (obrigatório por CLASSIFICAÇÃO — militar, SELinux); DAC (discretionary — o DONO do arquivo decide, Windows FS); RBAC (por FUNÇÃO); ABAC (atributos); time-of-day restriction.

Highlights que a prova cobra

- MAC: o sistema decide por classificação (militar/SELinux)
- DAC: o DONO decide (Windows file permission)
- RBAC: por função (o padrão enterprise); ABAC: por atributo dinâmico

Dicas de prova

- 'permissions determined by data classification'=MAC

Cenário clássico: 'arquivo só acessado por usuários com clearance alto'=MAC.

Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. Dar a cada usuário SÓ o acesso mínimo que ele precisa pra função é:
 - A) Menor privilégio
 - B) Separação de funções
 - C) Rotação de cargo
 - D) Need-to-know geográfico

2. O framework NIST CSF organiza a segurança em 5 funções. Quais são?

- A)** Instalar, Atualizar, Testar, Auditar, Arquivar
- B)** Identificar, Proteger, Detectar, Responder, Recuperar
- C)** Planejar, Fazer, Checar, Agir, Revisar
- D)** Prevenir, Punir, Prever, Provar, Publicar

3. Cenário corporativo (Access Controls): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'MAC: o sistema decide por classificação (militar/SELinux)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: MAC: o sistema decide por classificação (militar/SELinux)...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Access Controls): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'DAC: o DONO decide (Windows file permission)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: DAC: o DONO decide (Windows file permission)...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Access Controls): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'RBAC: por função (o padrão enterprise); ABAC: por atributo dinâmico'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: RBAC: por função (o padrão enterprise); ABAC: por atributo dinâmico...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Access Controls): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: "permissions determined by data classification'=MAC'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'permissions determined by data classification'=MAC...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Access Controls): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: "arquivo só acessado por usuários com clearance alto'=MAC.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'arquivo só acessado por usuários com clearance alto'=MAC....
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Access Controls): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'MAC: o sistema decide por classificação (militar/SELinux)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: MAC: o sistema decide por classificação (militar/SELinux)...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Access Controls): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'DAC: o DONO decide (Windows file permission)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: DAC: o DONO decide (Windows file permission)...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Access Controls): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'RBAC: por função (o padrão enterprise); ABAC: por atributo dinâmico'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: RBAC: por função (o padrão enterprise); ABAC: por atributo dinâmico...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO

- 1) A — Menor privilégio.** Least privilege (menor privilégio): ninguém tem mais permissão que o necessário. Reduz o estrago se a conta for comprometida.
- 2) B — Identificar, Proteger, Detectar, Responder, Recuperar.** NIST CSF = Identify, Protect, Detect, Respond, Recover. É o 'checklist mestre' citado em quase toda vaga. (A versão 2.0/2024 somou uma 6ª função, Govern — mas o SY0-701 ainda cobra as 5.) Decorar essas dá ponto fácil na
- 3) B — Implementar a solução correspondente: MAC: o sistema decide por classificação (m.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Access Controls): MAC: o sistema decide por classificação (militar/SELinux). As demais alternativas configuram violações graves de conf
- 4) B — Implementar a solução correspondente: DAC: o DONO decide (Windows file permisso.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Access Controls): DAC: o DONO decide (Windows file permission). As demais alternativas configuram violações graves de conformidade ou f
- 5) B — Implementar a solução correspondente: RBAC: por função (o padrão enterprise); AB.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Access Controls): RBAC: por função (o padrão enterprise); ABAC: por atributo dinâmico. As demais alternativas configuram violações grav
- 6) B — Implementar a solução correspondente: 'permissions determined by data classifica.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Access Controls): 'permissions determined by data classification'=MAC. As demais alternativas configuram violações graves de conformida
- 7) C — Implementar a solução correspondente: 'arquivo só acessado por usuários com clea.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Access Controls): 'arquivo só acessado por usuários com clearance alto'=MAC.. As demais alternativas configuram violações graves de con
- 8) C — Implementar a solução correspondente: MAC: o sistema decide por classificação (m.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Access Controls): MAC: o sistema decide por classificação (militar/SELinux). As demais alternativas configuram violações graves de conf
- 9) A — Implementar a solução correspondente: DAC: o DONO decide (Windows file permisso.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Access Controls): DAC: o DONO decide (Windows file permission). As demais alternativas configuram violações graves de conformidade ou f
- 10) B — Implementar a solução correspondente: RBAC: por função (o padrão enterprise); AB.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Access Controls): RBAC: por função (o padrão enterprise); ABAC: por atributo dinâmico. As demais alternativas configuram violações grav

